

Guía Práctica 7: Seguridad

Tomás F. Melli

November 2025

Índice

1	Ejercicio 1	2
2	Ejercicio 2	2
3	Ejercicio 3	3
4	Ejercicio 4	4
5	Ejercicio 5	5
6	Ejercicio 9	5

1 Ejercicio 1

Del siguiente criptograma se conoce que las letras fueron encriptadas usando un cifrado César.

```
pm fvb aopur aljouvsnf jhu zvscl fvby zljbypaf  
wyvisltz, aolu fvb kvua buklyzahuk aol wyvisltz  
huk fvb kvua buklyzahuk aol aljouvsnf.--iybjl zjoulply
```

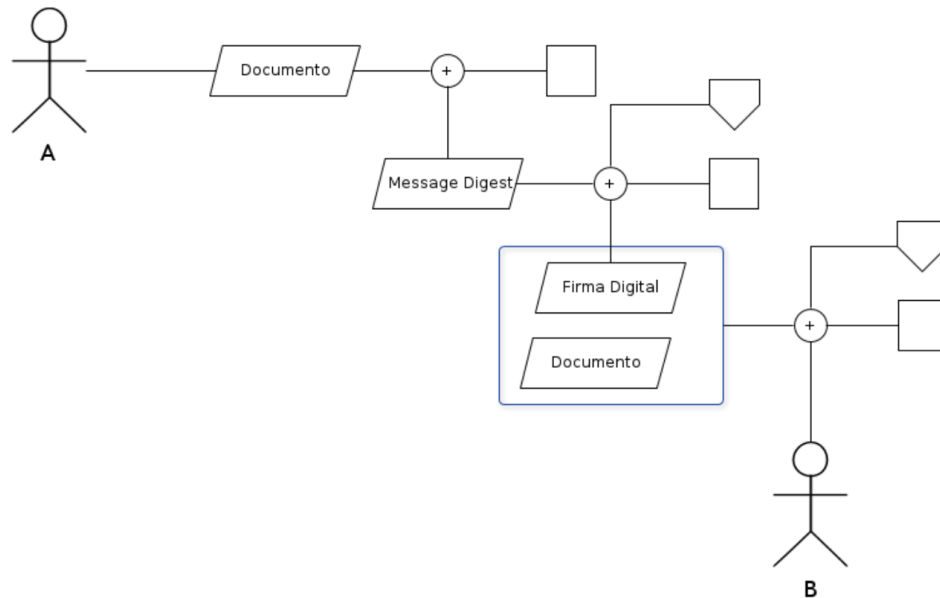
Asumir: que el texto original contenía letras sin tildes

Describe una estrategia que se pueda usar para descubrir el desplazamiento.

La manera más intuitiva es **brute force** con cada corrimiento. Es decir, al texto cifrado le aplicas un corrimiento inverso y si produce una salida coherente, ese es. Sino, otra manera es el **análisis de frecuencia** para encontrar el desplazamiento probable. Se puede usar **Cryptool 2** que es una herramienta para probar descifrarlo.

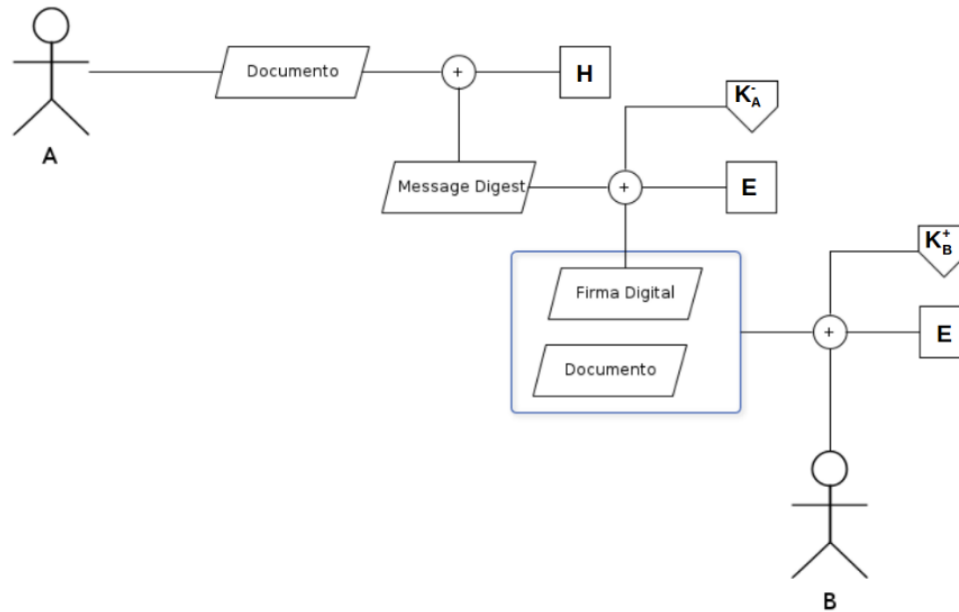
2 Ejercicio 2

A desea enviarle un mensaje a B de carácter importante. A quiere asegurarse de que nadie excepto B pueda leerlo y que B pueda confiar en que A fue quién envió el mensaje.



Basandose en el esquema a continuación, completando los cuadrados con algoritmos y las casitas con los parámetros adicionales que estos toman, explique cómo puede hacer A para construir el mensaje usando criptografía asimétrica, de manera de garantizar las propiedades de Confidencialidad y No repudio.

Sean K^A , la clave privada de A; K_B^+ , la clave pública de B; E un algoritmo de encriptación de clave asimétrica; y H una función de Hash, para garantizar Confidencialidad y Autenticación hay que hacer:



Explique qué debe hacer B para verificar que A fue quién envió el mensaje

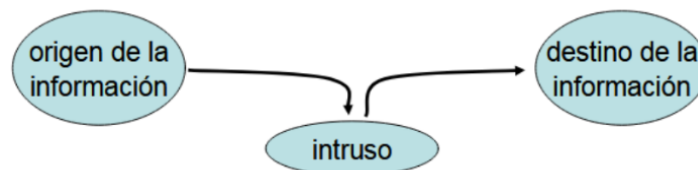
Dado el criptograma C que recibe B, se debe descifrar usando un algoritmo de clave asimétrica D con su clave privada K_B^- , obteniendo $D_{K_B^-}(C) = M + F$, donde M es el documento original que envía A, y F, la firma digital. Como B es el único capaz de descifrar el mensaje cifrado C, entonces queda garantizada la Confidencialidad. Luego, para verificar la firma, B debe descifrar la firma usando la clave pública de A (K_A^+) y comparar aplicando la misma función de Hash al documento: $D_{K_A^+}(F) == H(M)$, y así queda garantizado la autenticación de A sobre el mensaje enviado.

3 Ejercicio 3

A y B utilizan criptografía asimétrica para garantizar la confidencialidad sobre los mensajes que se envían. Para que puedan asegurarse que sus mensajes no sean leídos por nadie más, primero deben intercambiar sus claves públicas.

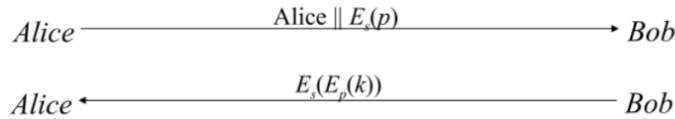
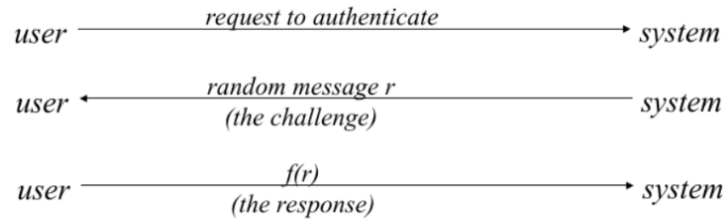
Explique cómo se puede vulnerar la confidencialidad de la comunicación entre A y B si alguien intercepta el intercambio de claves públicas.

Con un ataque MITM (Man-in-the-Middle) donde el atacante intercepta los mensajes y hace creer a las partes que la respuesta viene de la parte contraria. Como se ve en :

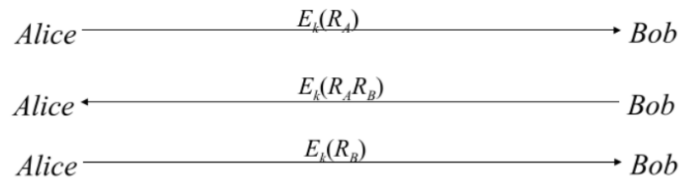


Explique qué piezas de información tienen los certificados digitales y cómo se usan para solucionar éste problema

En realidad el esquema que se usa no es sólo el certificado, sino un mecanismo challenge-response como el siguiente y para mitigar ataques el protocolo EKE (Encrypted Key Exchange):



Alice & bob comparten una clave de session secreta aleatoria k



4 Ejercicio 4

Muchos protocolos para establecer conexiones seguras usan handshakes para iniciar el sistema criptográfico. En este ejercicio tenga en mente SSL/TLS como sistema criptográfico a analizar.

De los siguientes parámetros indique la etapa del algoritmo donde se utiliza: **HELLO**, **Key - Exchange** o **Data-sharing**.

- Parámetros Criptográficos
- Valor al azar
- Conjunto de Algoritmos de encripción
- Versión Protocolo
- Certificado del destinatario (Peer)
- Clave Maestra (Masterkey)
- Criptograma

Respuesta :

Uso de parámetros en cada etapa del Handshake

- **HELLO**

- Parámetros criptográficos: se intercambian para acordar cómo se va a proteger la comunicación.
- Valor al azar (nonce): evita ataques de repetición (**replay attack**) y sirve para generar claves únicas.
- Conjunto de algoritmos de encripción (cipher suite): se negocia qué algoritmos usarán ambas partes.
- Versión del protocolo: permite acordar si usar TLS 1.2, 1.3, etc.
- Certificado del destinatario (peer): se envía aquí para autenticar al servidor (y opcionalmente al cliente).

- **Key-Exchange**

- Clave Maestra (Master Key): se genera a partir del intercambio de claves y de los valores aleatorios.

- **Data-Sharing**

- Criptograma: es el tráfico ya cifrado usando las claves derivadas de la Master Key.

Muestre mediante un diagrama de secuencia una posible implementación de un handshake para establecer una conexión. Considere los mensajes enviados, y si se envían en plano o como criptogramas.

5 Ejercicio 5

Suponga que una compañía necesita implementar un sistema que garantice la autenticidad de sus clientes usando un sólo servicio instalado en un servidor.

Se sabe que ssh admite autenticación por clave pública y privada mediante el método de challenge-response. Explique dónde y cuántas claves públicas y privadas deberían instalarse para que se pueda garantizar la autenticidad de los clientes usando ssh.

En el caso de SSH, las claves deben instalarse previamente en cada cliente y servidor, dependiendo de quién debe garantizar la autenticidad y sobre quién. Para que se pueda garantizar la autenticidad de N clientes (C_i , $1 \leq i \leq N$), cada uno de ellos debe generar un par de claves pública y privada $(K_{C_i}^+, K_{C_i}^-)$. Luego, deben instalarse las N claves públicas $K_{C_i}^+$ en el servidor, asociándolas a cada uno de los clientes.

Suponga ahora que los clientes necesitan garantizar la autenticidad del servidor de la compañía, ¿Dónde deberían instalarse las claves públicas y privadas?

Para garantizar la autenticidad del servidor, éste debe generar un par de claves pública y privada (K_S^+, K_S^-) y, luego, debe instalarse K_S^+ en cada cliente.

También se puede garantizar autenticidad estableciendo una conexión SSL/TLS que usa un handshake seguro intercambiando certificados digitales. Explique cómo cambian la soluciones de los incisos a. y b. si la compañía dispone de un certificado digital propio firmado por una autoridad certificante.

Primero que nada, todas las máquinas (clientes y servidor) tienen que tener instalado un certificado de una autoridad certificante (CA) que contiene su clave pública K_{CA}^+ .

En el handshake SSL/TLS, la autenticación del servidor es obligatoria. Éste debe generar un par de claves pública y privada (K_S^+, K_S^-) , generar su certificado, hacerlo firmar por la CA e instalarlo en el servidor para su posterior envío en el Handshake SSL.

Luego, para garantizar la autenticidad de los clientes C_i , cada uno de estos debe generar un par de claves pública y privada $(K_{C_i}^+, K_{C_i}^-)$, construir un certificado con la clave pública $K_{C_i}^+$ y hacerlo firmar por la autoridad certificante de manera que quede asociado con el nombre del cliente (C_i). El certificado que se debe instalar en cada cliente, por ejemplo, contendría la siguiente información:

$$(C_i, K_{C_i}^+, F_{CA, C_i})$$

donde

$$F_{CA, C_i} = E(H(C_i + K_{C_i}^+), K_{CA}^-)$$

donde E es un algoritmo de cifrado asimétrico y H es una función hash.

Luego, se instala cada certificado en cada cliente para que se envíe durante el Handshake SSL y para que el servidor pueda garantizar la autenticidad usando K_{CA}^+ para validar el certificado y, luego, $K_{C_i}^+$ para autenticar al cliente.

Si no se necesita autenticar clientes, se omite esta parte. En el handshake SSL/TLS, la autenticación del cliente es opcional.

6 Ejercicio 9

La empresa Security First expone una API usando el protocolo HTTP. Dicha API tiene un método getPrice que devuelve el precio de frutas usando la siguiente url: <http://api.securityfirst.com/?method=getPrice&fruit=Pera>. Además, la empresa tiene su propio servidor DNS autoritativo del dominio securityfirst.com.

Es necesario agregar un método nuevo a la API que haga lo mismo que el `getPrice` pero que provea el servicio sólo a usuarios autenticados brindando integridad y no repudio del lado del servidor sobre los pedidos de los usuarios.

1. Explique qué información tiene que tener el cliente y el servidor para que esto sea posible.
2. Muestre una posible url que permita procesar el pedido.
3. Explique qué es lo que tiene que hacer cada parte para garantizar lo solicitado.

Nota: Es requisito para lo anterior no usar encriptación sobre la totalidad del mensaje y no manejar sesiones. La idea acá es extender la funcionalidad usando la firma digital dado que nos piden Integridad y No repudio.

1. Cada cliente debe tener generada una clave pública y su respectiva clave privada. El server debe tener la clave pública de cada cliente autorizado a consumir la API. Se asume que este intercambio se realizó previamente y de manera segura. Además, cliente y servidor deben ponerse de acuerdo en los algoritmos a usar para implementar firma digital. Una posible combinación es RSA para criptografía asimétrica y SHA-3 para el cálculo de hashes.
2. `http://api.securityfirst.com/?method=getPrice&fruit=Pera&signature=FIRMA&clientId=33`
3. El cliente debe realizar un hash con el valor de los parámetros `method`, `fruit` y `clientId` (Integridad). Ese hash debe ser usado para la firma digital (No repudio), para eso usa su clave privada. La firma digital se utiliza donde está la palabra `FIRMA` en el punto 2. El servidor, al recibir el pedido, debe validar la firma digital usando la clave pública del cliente. Esa clave la obtiene buscándola por `clientId` en la colección de usuarios autorizados que almacena (Autenticación). Finalmente, debe tomar el valor de los parámetros `method`, `fruit` y `clientId` para calcular el hash, compararlo con lo incluido en la firma digital y así validar integridad.

Notas finales

Pero... ¿Qué sucede si alguien conoce la nueva URL propuesta? La puede ejecutar cuantas veces quiera, como si estuviera realizando nuevas peticiones para conocer el precio de un producto. Si por cada ejecución del método la empresa Security First cobra un valor por la operación, alguien podría generar costos para los clientes, que estos pudieran negar: no se cumple el No Repudio. Esto se conoce como ataque de repetición. Para su estudio independiente, los invitamos a buscar más información al respecto en ???. Como dijimos al principio, siempre debemos estar alertas: la seguridad consiste en hacer que el riesgo se reduzca a niveles aceptables, debido a que el riesgo es inherente a cualquier actividad y nunca puede ser eliminado.